Vulnerability Assessment

Risk Assessment & Executive Summary

Target System: metasploitable (192.168.246.131)

Tools Used: Nmap, Nikto, Nuclei, xsltproc

1. Risk Assessment Table

The table below summarizes the key vulnerabilities identified during the assessment, classified by inherent risk and mapped to relevant compliance frameworks.

Finding	Affected Service	CVE/Reference	Risk	Compliance Violation	Business Impact
vsFTPd 2.3.4 Backdoor	FTP (21)	CVE-2011-2523	H	CIS 7.1 (Patch Mgmt); NIST CSF PR.IP-1	Unauthenticated remote root; full system compromise
Anonymous FTP Login Allowed	FTP (21)	N/A	H	CIS 5.2; NIST CSF PR.AC-1	Unauthorized file access & data exposure
Unreal IRCd Backdoor	IRC (6667/6697)	CVE-2010-2075	H	CIS 7.1; NIST CSF PR.IP-1	Remote code execution as service user
Samba 'username map script' RCE	SMB (139/445)	CVE-2007-2447	H	CIS 7.1; NIST CSF PR.IP-1	Remote command execution; lateral movement
distccd Remote Code Execution	distcc (3632)	CVE-2004-2687	H	CIS 4.8 (Unnecessary services)	Arbitrary command execution on host
Exposed 'root shell' Bind Shell	bindshell (1524)	N/A	H	CIS 4.8; NIST CSF PR.AC-1	Instant unauthenticated root access
Unencrypted Telnet Service	Telnet (23)	N/A	H	NIST CSF PR.DS-2; PCI DSS 4.1	Credential sniffing; session hijacking
Legacy r-services (rexec/rlogin)	512/513/514	N/A	H	CIS 4.8; NIST CSF PR.DS-2	Plaintext trust-based auth; credential theft
Weak / Default VNC Authentication	VNC (5900)	N/A	H	CIS 5.2; NIST CSF PR.AC-1	Full remote desktop takeover
PHP CGI Argument Injection (RCE)	HTTP (80)	CVE-2012-1823	H	CIS 7.1; PCI DSS 6.2	Remote code execution via web server
Outdated PHP 5.2.4 & Apache 2.2.8	HTTP (80)	Multiple	H	CIS 7.1; PCI DSS 6.2	Numerous known web-stack exploits
phpinfo() & phpMyAdmin Exposed	HTTP (80)	CWE-552	M	PCI DSS 6.5; NIST CSF PR.IP-1	System info disclosure; DB admin exposure

Finding	Affected Service	CVE/Reference	Risk	Compliance Violation	Business Impact
Obsolete SSLv2 / Weak Ciphers	SMTP (25)	N/A	**M**	PCI DSS 4.1; NIST CSF PR.DS-2	Decryptable traffic; MITM risk
Exposed DBs + Default PostgreSQL Login	3306 / 5432	Default creds	**H**	CIS 5.2; PCI DSS 1.3	Confirmed postgres/postgres access; data breach
Directory Indexing & TRACE Enabled	HTTP (80)	CVE-1999-0678	**L**	PCI DSS 6.5; CIS 4.8	Information disclosure; XST

Inherent Risk Criteria

- **High (H):** Easy to exploit; leads to full system compromise.
- **Medium (M):** Requires some skill; leads to data leakage.
- **Low (L):** Information disclosure; low direct impact.

2. Executive Summary

To: IT Management
From: GRC Audit Team
Date: 23rd of October, 2026
Subject: High-Risk Findings on Development Server 'metasploitable'

2.1 Overview

A vulnerability assessment of the internal development server (192.168.246.131) revealed multiple critical security vulnerabilities that pose an immediate and high risk to the organization's information assets. The scan identified more than 20 open network services, many running severely outdated software with publicly known exploits. The system is non-compliant with several key organizational policies based on the CIS Controls and fails core requirements of the NIST Cybersecurity Framework.

2.2 Key Findings & Risks

- **Critical Risk – Remote System Compromise:** The FTP service (vsFTPd 2.3.4) contains a known backdoor (CVE-2011-2523) granting attackers full control without authentication. Additional backdoors were found in the IRC (CVE-2010-2075), Samba (CVE-2007-2447), and distcc (CVE-2004-2687) services, and an exposed root bind shell on port 1524. This violates our patch management policy (CIS Control 7.1).
- **High Risk – Data Interception:** Services including Telnet, FTP, and legacy r-services transmit credentials in plaintext, and the mail service still supports obsolete SSLv2 encryption. This violates data-protection standards (NIST CSF PR.DS-2) and risks credential theft.
- **High Risk – Weak Authentication:** Anonymous FTP access is permitted, weak FTP passwords were successfully cracked during the scan, and the PostgreSQL database was reachable with default credentials (postgres/postgres). Weak/default credentials are also in use on services such as VNC, substantially increasing the risk of unauthorized access (CIS 5.2).
- **Medium Risk – Information Disclosure:** The web server exposes phpinfo() output, an unprotected phpMyAdmin console, browsable directories, and the HTTP TRACE method, leaking system detail useful to attackers (PCI DSS 6.5).

2.3 Recommended Actions

- **Immediate Isolation:** Remove the server from the network until it is remediated.
- **Remediate:** Apply current security patches, prioritizing vsFTPd, Samba, UnrealIRCd, and the web stack (PHP/Apache).
- **Harden:** Disable unnecessary and insecure services (Telnet, rexec/rlogin, distcc, bind shell); enforce strong passwords and encrypted protocols (SSH, TLS).
- **Restrict Access:** Firewall database ports (MySQL/PostgreSQL) and protect administrative interfaces such as phpMyAdmin.
- **Process Review:** Reinforce secure-baseline procedures so systems are hardened before deployment.

Conclusion: *The server in its current state is unfit for any network-connected environment. Immediate isolation and remediation are required to bring it into compliance and reduce organizational risk.*

3. Evidence (Screenshots)

The following screenshots document the assessment workflow, from network discovery through automated vulnerability scanning.

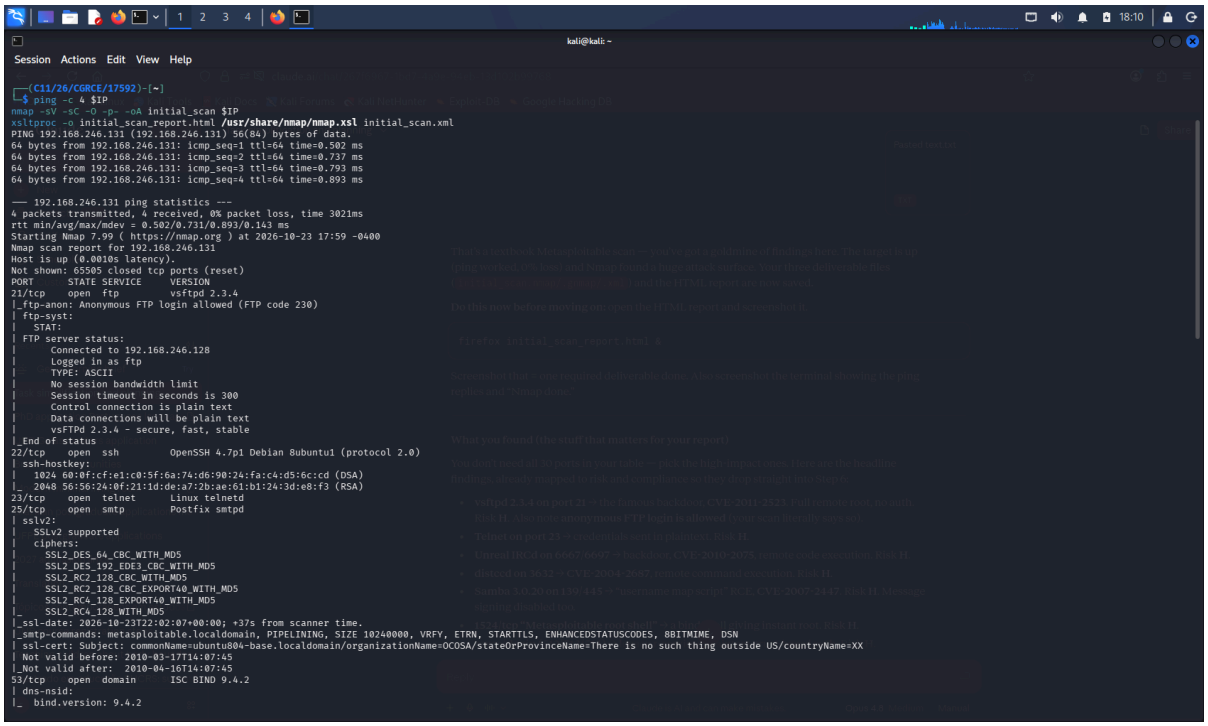


Figure 1 - Network discovery and Nmap scan: host confirmed alive (ping) and open ports/services enumerated on 192.168.246.131.

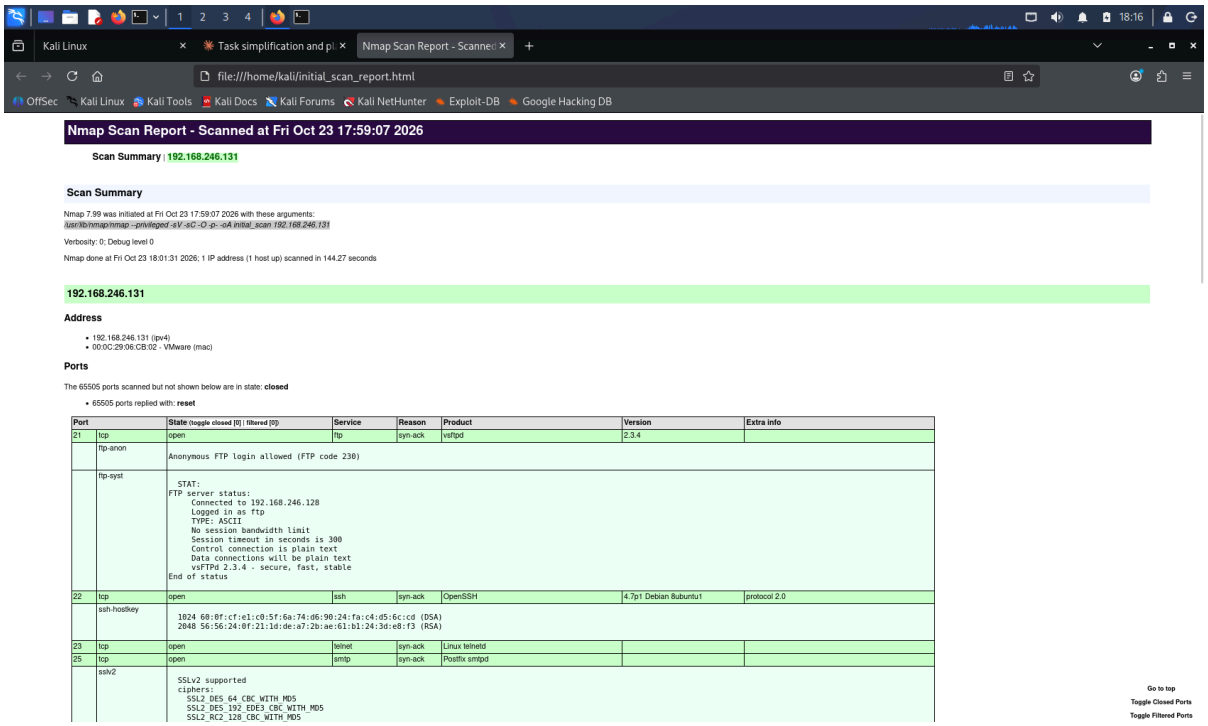


Figure 2 - Nmap HTML report (initial_scan_report.html) generated with xsltproc, showing the formatted scan summary and open ports.

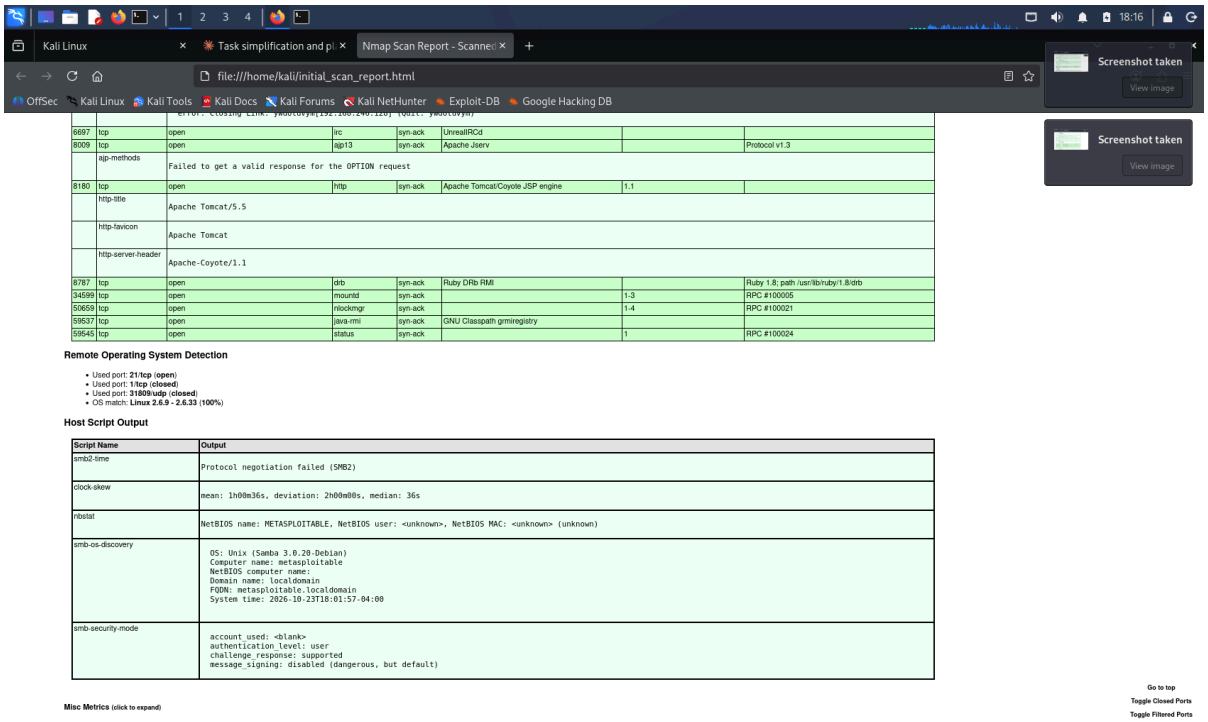


Figure 3 - Nmap HTML report (continued): service versions, OS detection, and SMB host-script results.

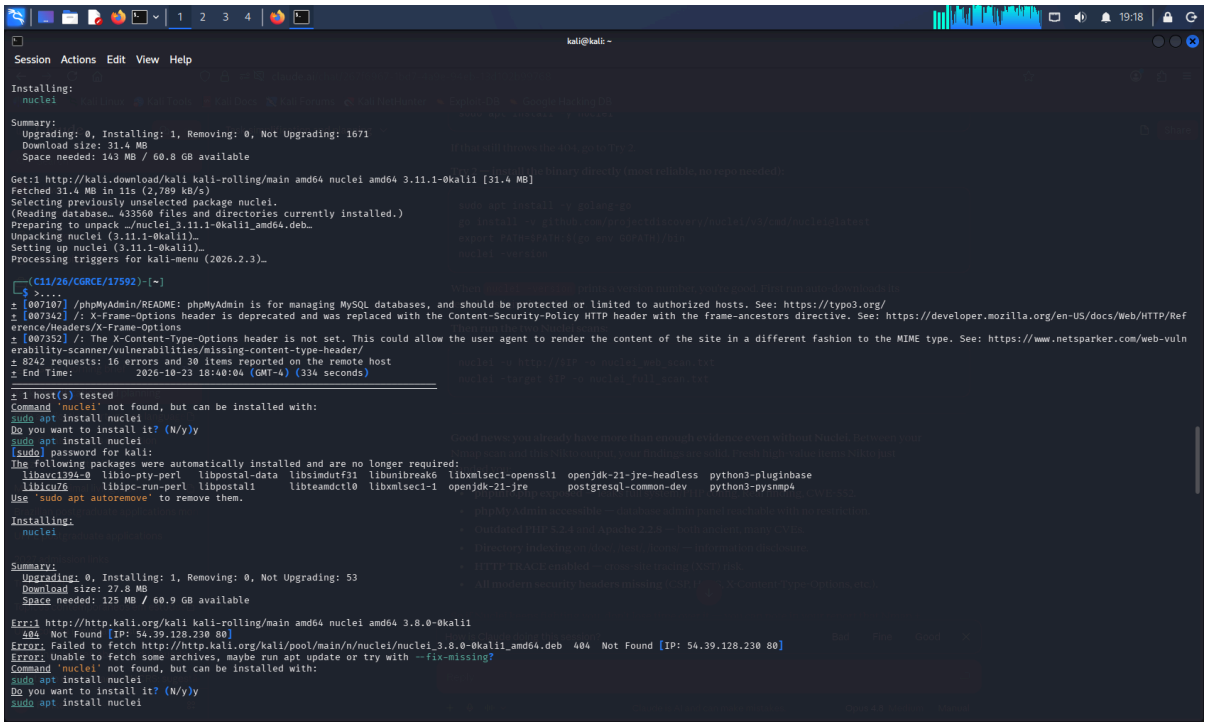


Figure 4 - Nikto web server scan results (nikto_scan.txt): outdated PHP/Apache, phpinfo, phpMyAdmin, directory indexing and missing security headers.

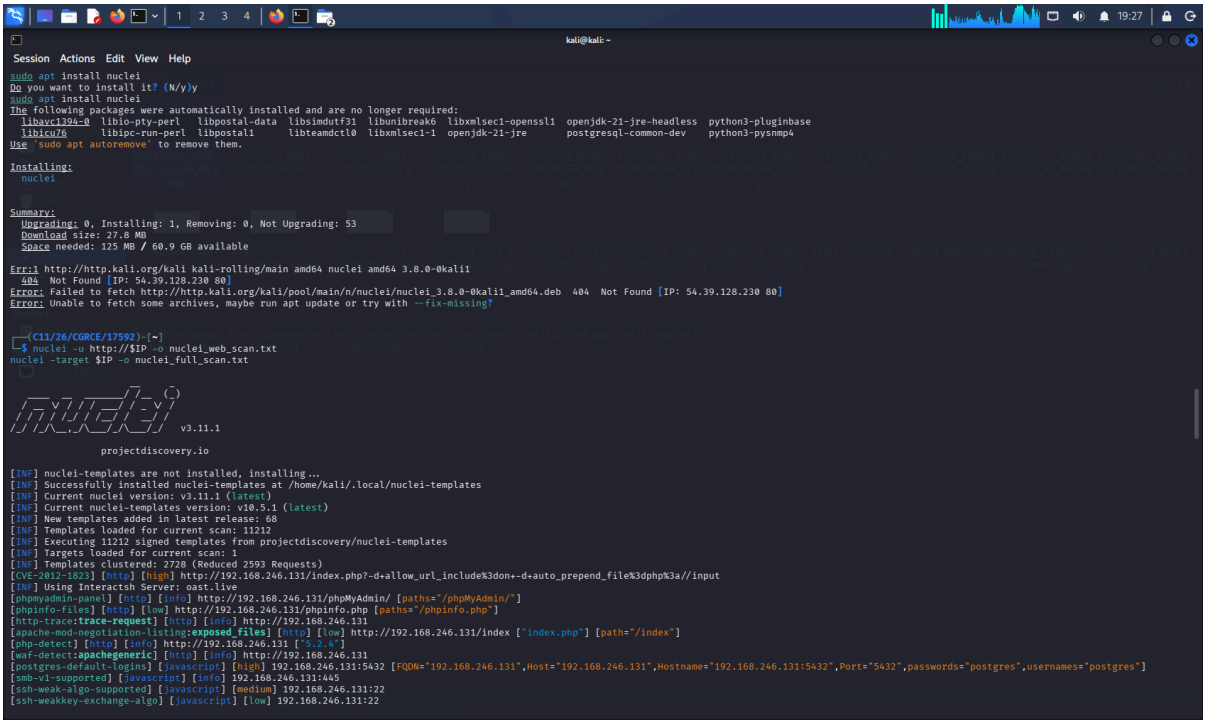


Figure 5 - Nuclei vulnerability scan in progress against the target, loading 11,000+ templates.

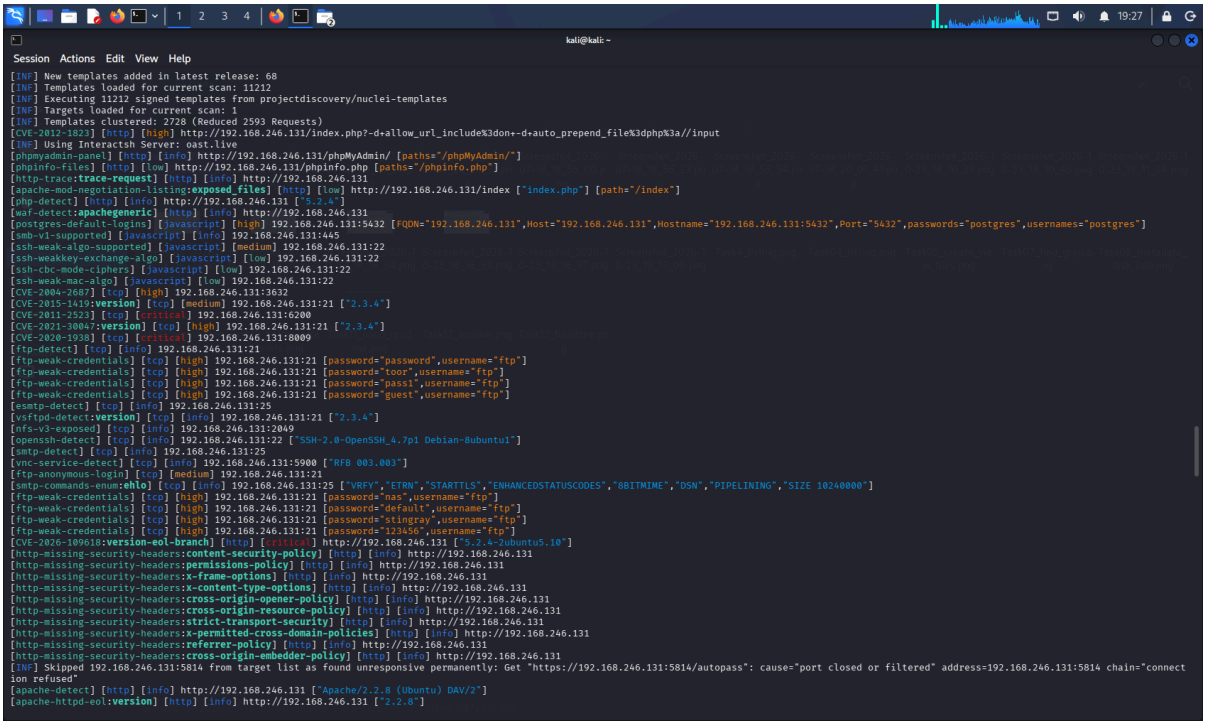


Figure 6 - Nuclei findings: confirmed CVE-2011-2523 (critical), CVE-2012-1823, distcc RCE, weak FTP credentials, and default PostgreSQL logins.